

ARP Spoofing

Ettercap

: RedHat 한준희

목차

Table of Contents

ARP 프로토콜의 이해03p

ARP의 이론
ARP의 작동원리

ARP 스푸핑04p

ARP스푸핑의 정의
공격원리

환경구축08p

실습망 구축
실습 서버 설정

실습 & 분석11p

공격 실습
패킷 분석

기타 기술20p

NDP Poisoning
ICMP redirect
Port stealing
DHCP spoofing

ARP

ARP 란

IPv4에서 IP -> MAC 주소 변환을 담당하는 프로토콜이다.
L2 통신을 위해서는 필수적인 프로토콜

1

ARP Request / Reply 작동방식

- ARP Request : 브로드캐스트
- ARP Reply: 유니캐스트
- 결과는 Cache Table에 저장

2

ARP Cache Table

- IP-MAC 매핑정보가 저장됨
- 타임아웃이 있으며 갱신 가능
- 보안 X -> 누구나 업데이트 가능

3

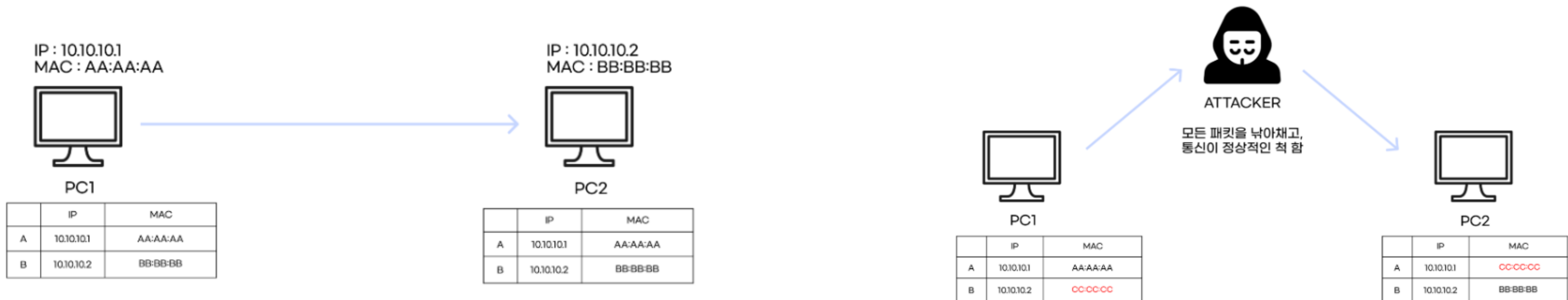
ARP 취약점

- 인증, 무결성 검사가 없다.
- Request 없이 Reply만 보내도 수용(Gratuitous ARP)
- 최근의 Reply를 믿는다.

ARP Spoofing

ARP Spoofing 이란

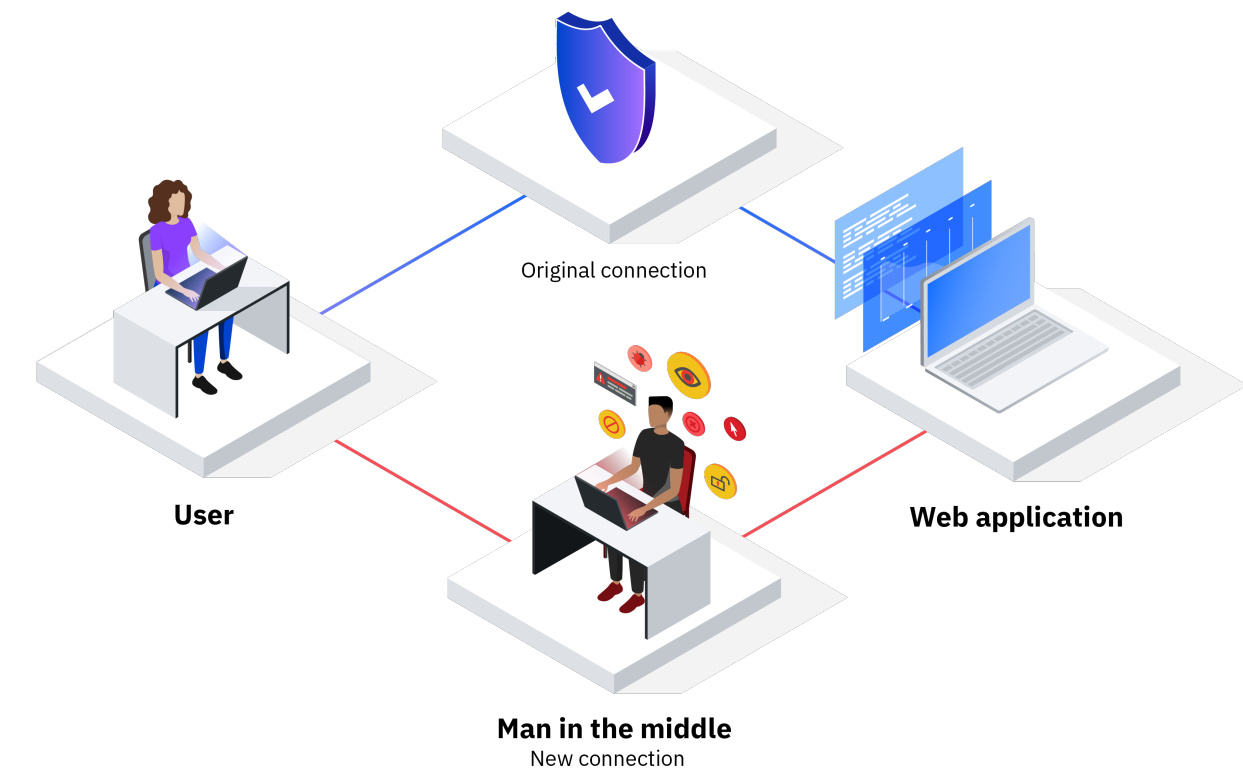
- LAN에서 사용하는 ARP 프로토콜의 허점을 이용해 자신의 MAC(Media Access Control) 주소를 다른 컴퓨터의 주소인것 처럼 속이는 MITM(Man In The Middle)공격이다



MITM Attack

Mitm Attack(Man In The Middle) 이란

- 글자 그대로 누군가의 사이에 끼어드는 것.
- 통신을 하고 있는 두 주체 사이에 공격자가 몰래 개입하여 트래픽을 가로채고, 변조하며 당사자들은 서로 정상 통신한다고 생각하는 공격.
- 조건 : 중간에 위치, 양방향 통신을 모두 가로채거나 조작 가능, 송신자, 수신자는 공격자의 존재를 인지하지 못한다.



Ettercap

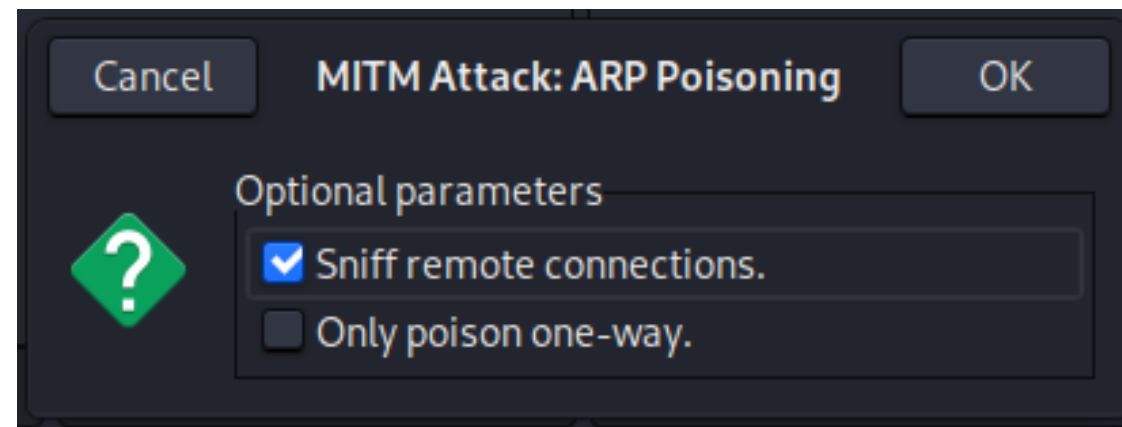
Ettercap 이란

- ARP 스푸핑을 이용해 네트워크 트래픽을 가로채는 중간자 공격 전문 도구이다.
- 가로챈 실시간 데이터를 분석하거나, 변조하여 비밀번호 탈취, DNS 스푸핑 등 다양한 보안 테스트 및 공격에 사용된다.
- 네트워크 분석 및 보안 감사 목적으로 개발 되었으나, 악의적인 해킹 공격에도 사용될 수 있다.



실습

Kali - ettercap



```
GROUP 1: 1.1.1.6 00:0C:29:FC:96:69  
GROUP 2: 1.1.1.1 CA:01:45:FC:00:39  
ARP poisoner deactivated
```

[지구본] -> [ARP Poisoning] -> sniff ~ 체크 상태로 OK

공격전 윈도우로 넘어가서 1.1.1.1의 맥주소를 일단 확인해보자

Gateway

```
인터페이스: 1.1.1.6 --- 0x4
인터넷 주소      물리적 주소      유형
1.1.1.1          ca-01-45-fc-00-39   동적
1.1.1.4          00-0c-29-07-b3-c0   동적
1.1.1.5          00-0c-29-a9-09-06   동적
1.1.1.255        ff-ff-ff-ff-ff-ff   정적
224.0.0.22        01-00-5e-00-00-16   정적
224.0.0.252       01-00-5e-00-00-fc   정적
239.255.255.250   01-00-5e-7f-ff-fa   정적
```

```
인터페이스: 1.1.1.6 --- 0x4
인터넷 주소      물리적 주소      유형
1.1.1.1          00-0c-29-07-b3-c0   동적
1.1.1.4          00-0c-29-07-b3-c0   동적
1.1.1.5          00-0c-29-a9-09-06   동적
1.1.1.255        ff-ff-ff-ff-ff-ff   정적
224.0.0.22        01-00-5e-00-00-16   정적
224.0.0.252       01-00-5e-00-00-fc   정적
239.255.255.250   01-00-5e-7f-ff-fa   정적
```

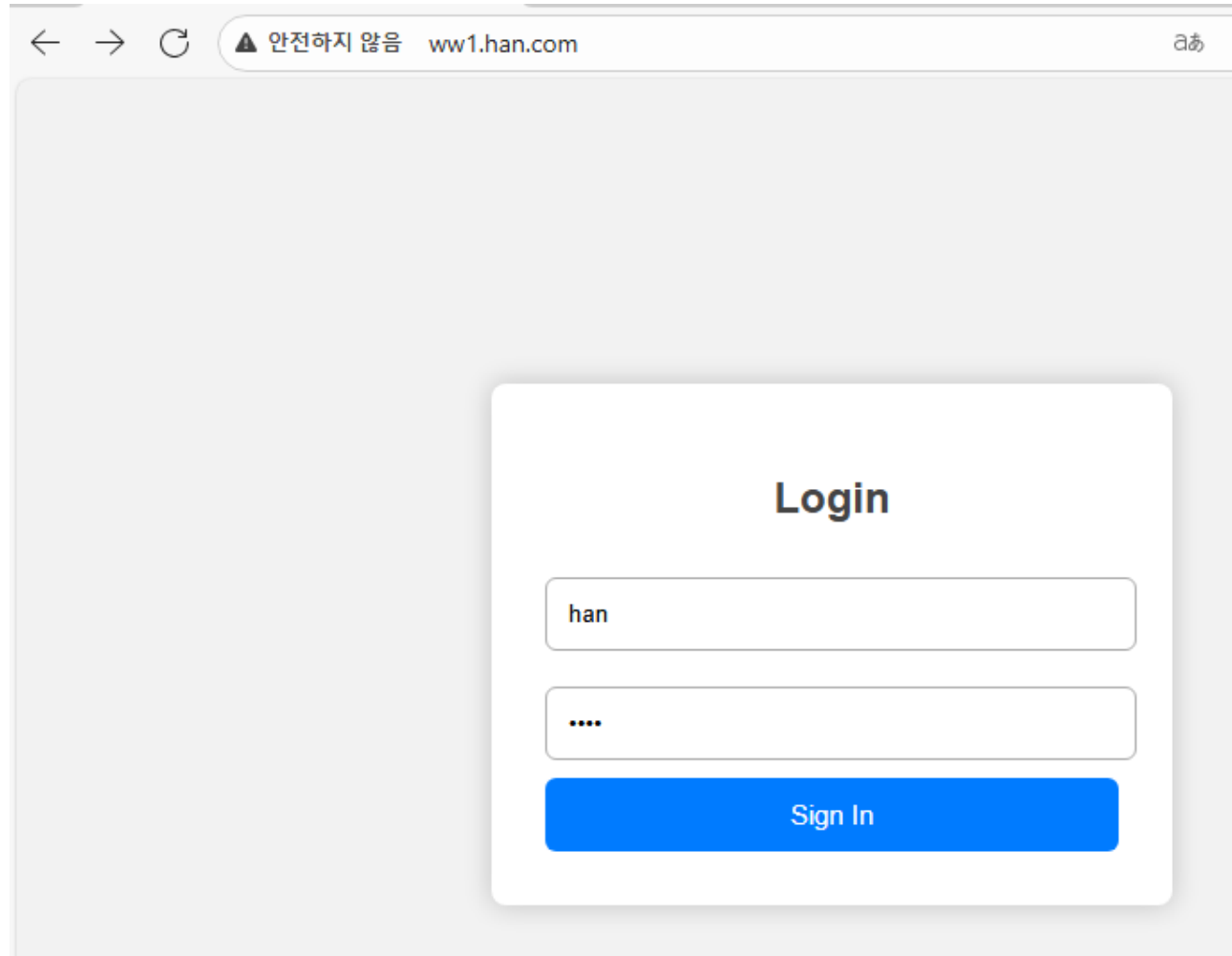
```
valid_lft forever preferred
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP>
    link/ether 00:0c:29:07:b3:c0 bcast:01:00:5e:00:00:01
```

본인 컴 윈도우 X, Vm웨어에서 실행한 윈도우 10에서 윈도우 + R을 눌러 cmd를 입력후 터미널을 실행해준다

arp -a 를해서 게이트웨이 아이피가 나오면 good, 나오지 않는다면 ping [게이트웨이]한 후엔 나온다.

공격전과 공격후 MAC주소의 변화를 관찰하자.

패킷 분석 준비



칼리에서 와이어샤크 실행후 eth0으로 들어가두자

본인 컴 윈도우 X, Vm웨어에서 실행한 윈도우 10 브라우저를 열어 아까 설정한 도메인 주소로 들어간다.

뜨면 id, pw를 입력후 sign in을 누른다.

GNS3 - Wireshark

http.request.method == POST						
No.	Time	Source	Destination	Protocol	Length	Info
4351	207.186660	1.1.1.6	1.1.1.5	HTTP	693	POST /login.php HTTP/1.1
61584	3641.941761	fe80::f0c5:35b4:29b...	fe80::7c35:363e:502...	HTTP/X...	807	POST /05617db0-b3df-4...
61843	3643.726081	fe80::f0c5:35b4:29b...	fe80::7c35:363e:502...	HTTP/X...	807	POST /05617db0-b3df-4...

```
> Hypertext Transfer Protocol
  > HTML Form URL Encoded: application/x-www-form-urlencoded
    > Form item: "username" = "user"
    > Form item: "password" = "1111"
```

칼리에서 wireshark를 실행후 eth0을 누르고 필터링을 위 사진과 같이 걸어준다.

http <- 필터링

본인이 입력한 ID PW가 나온다.

ARP 정적으로 수정

```
인터페이스: 1.1.1.6 --- 0x4
인터넷 주소      물리적 주소      유형
1.1.1.1          ca-01-45-fc-00-39   정적
1.1.1.4          00-0c-29-07-b3-c0   동적
1.1.1.5          00-0c-29-a9-09-06   동적
1.1.1.255        ff-ff-ff-ff-ff-ff   정적
172.16.28.100    00-0c-29-00-00-00   동적
```

cmd를 관리자모드로 실행시켜 준다.

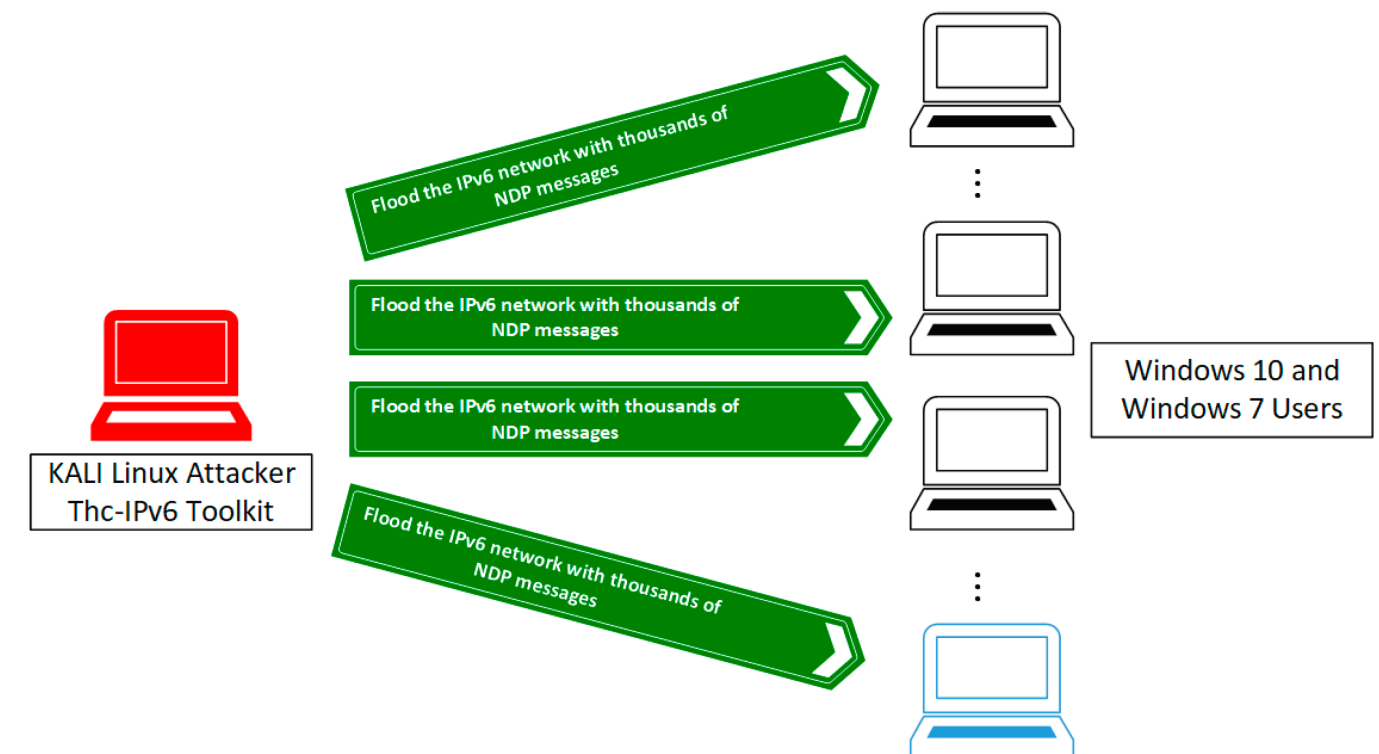
netsh interface ipv4 add neighbors "Ethernet0" 1.1.1.1 <MAC주소>

arp -a를 하면 정적으로 바뀌었을것이다.

NDP Poisoning

NDP(Neighbor Discovery Protocol) Poisoning 이란

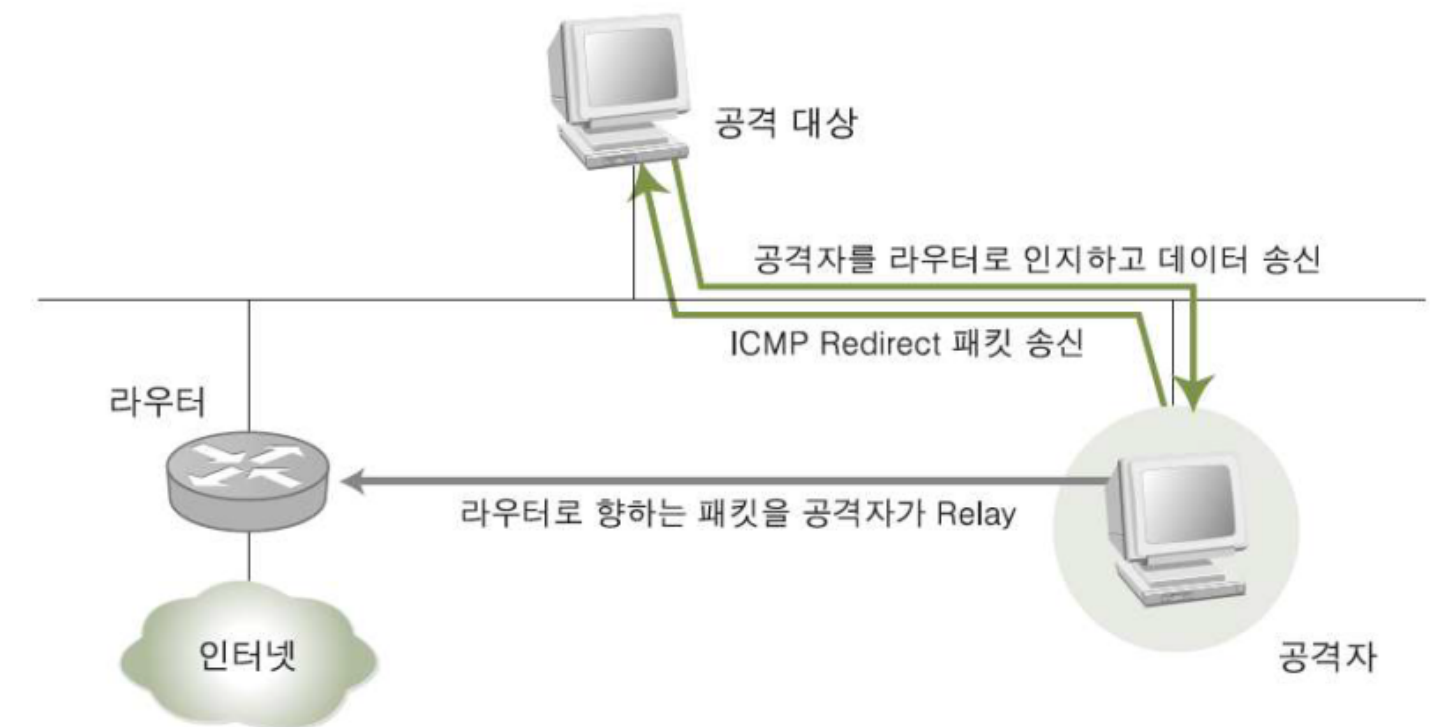
- NDP 포이징은 IPv6에서 ARP 스푸핑처럼 MAC 주소 매핑을 위조하는 공격이다.
- 공격자가 가짜 ICMPv6 패킷을 보내 트래픽을 자신에게 유도한다.
- 패킷 가로채기, 도청, 세션 탈취가 가능해진다.



ICMP redirect

ICMP redirect 이란

- Ettercap의 ICMP Redirect는 "이 목적지는 라우터 말고 나를 통해서만 가라"라고 속이는 공격이다.
- 피해자의 라우팅 테이블이 조작되어 모든 특정 목적지 트래픽이 공격자로 우회된다.
- MITM, 패킷 가로채기, 세션 탈취가 가능한 공격이다.

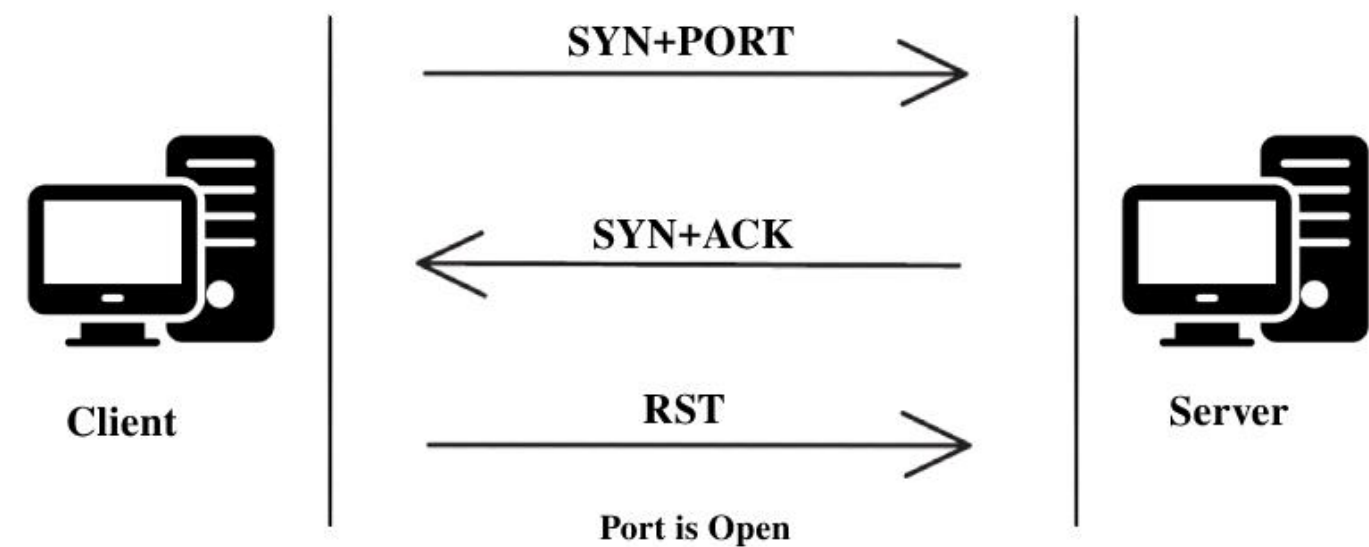


Port stealing

Port stealing 이란

- 스위치의 MAC 주소 테이블을 속여 특정 피해자의 트래픽을 공격자 포트로 보내게 만드는 공격이다.
- 공격자가 가짜 소스 MAC으로 ARP/프레임을 보내 MAC 테이블을 덮어써 스위치가 트래픽을 공격자에게 전달하게 만든다
- 피해자 트래픽을 스니핑, 도청, MITM 할수 있다.

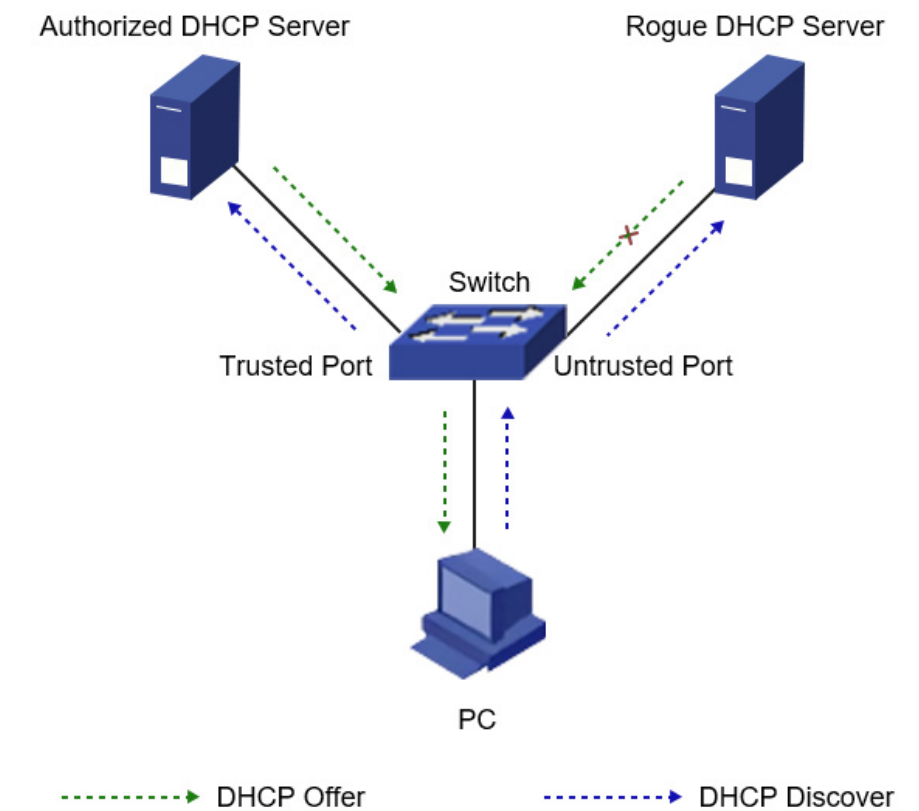
Port Scanning Attack



DHCP spoofing

DHCP spoofing 이란

- 공격자가 가짜 DHCP 서버로 위장해 피해자에게 잘못된 IP, 게이트웨이, DNS 정보를 주는 공격이다.
- 피해자는 공격자가 준 설정을 사용하게 되어 트래픽이 공격자로 향하게 됨.
- MITM, 도청, 피싱 유도, 네트워크 통제가 가능하다.



감사합니다.